

Implementing and Logging AWS Security Hub Generated Findings

By DQuez Carr
Cloud Security Final Paper

Abstract

The basic design for a cloud-based security system developed with AWS is presented in this paper, illustrating the usefulness of the cloud security concepts covered in MCY 612. To identify, track, and address security issues in a virtualized cloud environment, the architecture makes use of AWS-native services including Amazon GuardDuty, AWS Security Hub, and AWS Config. Compute, networking, and storage three essential elements of cloud infrastructure are protected by layered security measures, compliance guidelines, and industry best practices like encryption, access logging, and the least privilege principle. The article links theoretical ideas like cloud security models, identity and access management, infrastructure protection, and automated threat detection to a functional cloud security framework through a complete system overview, architectural design, and incident response procedure.

Keywords

AWS Config, S3, IAM, Guardduty, Securityhub, AWS Cli, FSBP compliance standards

Introduction

Presenting a conceptual architecture for a security system constructed with Amazon Web Services AWS is the main objective of this study. The architecture shows how several AWS-native services can be used to safeguard computing, networking, and storage resources, among other security requirements of a cloud-based IT infrastructure. The purpose of the paper is to demonstrate how cloud security best practices may be applied in a practical setting using AWS tools and services by utilizing concepts covered in MCY 612.

The paper is organized as follows to help achieve this goal it starts with an introduction that emphasizes the significance of AWS security design. The problem statement and design objectives are defined in the next part, which also lists the IT system's components and security specifications. After that, a review of the material covered in MCY 612 links theoretical understanding to real-world application. The conceptual security design, together with an architectural diagram and an explanation of each

AWS service utilized, is then presented in the paper. Workflows for detection and reaction are demonstrated through an examination of a fictitious security event. A discussion of how the concept would be assessed if it were put into practice follows here. Using the AWS Pricing Calculator, an economic study calculates the system's monthly operating costs. A summary of the design and recommendations for additional research are included in the paper's conclusion.

Because it serves as the foundation of a safe, dependable cloud environment that permits businesses to grow and innovate without sacrificing data security, AWS security design is important. AWS facilitates the cloud migration of more companies by integrating secure elements into its infrastructure. Customers no longer have to worry about maintaining physical hardware, allowing them to concentrate on safeguarding their data and apps with strong software-based security solutions. By using this method, businesses may have enterprise-level protection without having to deal with the expenses and hassles of facility maintenance.

The shared responsibility paradigm that AWS security design encourages is another factor that makes it so crucial. Customers are in charge of protecting the data, apps, and user access they store on the cloud, while AWS handles the security of the cloud's infrastructure. With this paradigm, clients can still rely on AWS's reliable, internationally audited infrastructure while having the freedom to put their own security measures in place. AWS also makes it easy for clients to fulfill industry standards and safeguard sensitive data by providing a variety of security solutions, professional support, and compliance certifications.

The AWS IT system I'm developing is a simple cloud-based application environment designed for security service testing and demonstration, including AWS Security Hub, GuardDuty, and AWS Config. The system generates security results for examination by simulating common workloads using a modest number of compute resources. Route tables, internet gateways, and security groups are used in networking to control access. Configuration logs,

reports, and application data are stored on Amazon S3's storage platform.

Several AWS services are integrated from a security standpoint to satisfy fundamental compliance and protection requirements. Configuration tracking and compliance audits of AWS resources are made possible via AWS Config. GuardDuty is set up to constantly scan for unwanted or malevolent activities, including instance compromise and reconnaissance. A centralized picture of compliance and threat posture is provided by Security Hub, which is able to compile and correlate security results from various services. Strict policies are used to enforce identity and access management (IAM), guaranteeing that resources are only accessible by authorized users and roles. The least privilege principle is followed by the system.

Key elements of the security paradigm include encryption and logging in addition to threat detection and configuration monitoring. Access logs are enabled for audit trails, and server-side encryption is enabled to safeguard data stored in S3 buckets. In order to record network-level activity for analysis, VPC flow logs are enabled. The AWS Foundational Security Best Practices standard is activated in Security Hub to further guarantee compliance. Even in a small-scale demonstration setting, these security techniques work together to create a layered defense strategy that mirrors best practices for protecting cloud infrastructure.

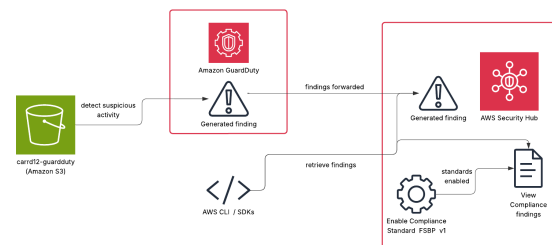
Knowledge gained in MCY 612

The diagram's conceptual design demonstrates how the skills learned in MCY 612 have been used to create a cloud architecture with a security focus. The utilization of managed services like Amazon GuardDuty and AWS Security Hub, which are essential to contemporary cloud-native security operations, reflects topics like Cloud Security Overview and AWS Security. AWS-native detection services are used to identify and escalate abnormal behavior in an S3 bucket as part of the system's layered protection approach. IAM supports safe access and control of services like GuardDuty and Security Hub, in line with the recommended practices discussed in Topic 3, even if it is not specifically depicted in the graphic.

GuardDuty's ability to monitor API activity and relay results to Security Hub is another way that the architecture incorporates the concepts of Infrastructure Protection and Logging and Monitoring. Despite the exclusion of compute-specific components like EC2 from the

present cost model, this illustrates the application of Topics 4-6 on safeguarding the network, computation, and storage layers. While Detection and Incident Response (Topic 8) is reflected in the way alerts are generated, correlated, and made actionable through the interaction between GuardDuty and Security Hub, Logging and Monitoring (Topic 7) is illustrated by the centralized retrieval and analysis of findings. This architecture offers a simplified illustration of how proactive security threat detection and remediation are supported by cloud-native technology.

Conceptual Design



This diagram shows an AWS security monitoring process where Amazon GuardDuty analyzes suspicious activity found in an S3 bucket carrd12-guarddduty and produces security findings. AWS Security Hub receives these results automatically for integration and centralized visibility. The AWS Foundational Security Best Practices (FSBP) standard is enabled in Security Hub, enabling it to assess compliance and produce relevant results. The system supports continuous threat detection and compliance monitoring by allowing users to download and examine all findings using the AWS CLI or SDKs.

My conceptual design which includes AWS Security Hub, GuardDuty, and AWS Config, is intended to serve as a demonstration environment for testing important security services. Route tables, security groups, and an internet gateway are used to control networking, while Amazon S3 is used to store logs and application data.

GuardDuty is a threat detection service that keeps an eye out for illegal or malicious activity on AWS accounts and workloads. It looks for activities like odd API calls, possible account compromise, and reconnaissance assaults using machine learning and threat intelligence feeds.

A comprehensive view of your security posture across all AWS accounts is offered by Security Hub. It compiles and evaluates security findings from many services, including third-party tools,

GuardDuty, and Config. Additionally, Security Hub supports compliance requirements, assisting customers in effectively identifying and resolving security issues.

Any quantity of data can be stored and retrieved from any location on the internet with Amazon S3, an object storage service. S3 is used in this system to store logs and data that may be examined for unusual activities. It is frequently used for application data storage, logging, and backup since it is robust and scalable.

With the help of the service AWS Config, you can examine, audit, and analyze how your AWS resources are configured. It monitors configuration changes over time and assists in enforcing compliance by comparing them to external regulations or internal policies.

You can safely manage access to AWS resources and services with IAM. It enforces the least privilege concept by allowing you to create users, groups, and roles with particular permissions. IAM is necessary for setting services like Config and GuardDuty and is a foundation for the secure operation of all other services.

AWS Config keeps track of resource changes, GuardDuty keeps an eye out for threats, and Security Hub compiles information from several services to secure the environment. IAM policies make sure that only authorized access is permitted by enforcing the least privilege principle. VPC flow logs for network monitoring, encrypted S3 storage, and compliance checks under the AWS Foundational Security Best Practices standard are further safeguards. A useful paradigm for comprehending and implementing cloud security best practices is produced by this layered security approach.

Security Workflow example

Through malware, phishing, or disclosed secrets, an attacker obtains legitimate AWS credentials and uses them to gain access to a particular S3 bucket within your AWS system. The IP address of the attacker corresponds to one on your company's unique threat list, which may have been discovered through prior malicious conduct. The attacker pulls objects (files) from the bucket using the GetObject API call; these files may include sensitive information like credentials, internal reports, or customer details. Conventional perimeter protections like firewalls or IAM-based access alerts might not detect the call right away because it was authenticated.

If left unnoticed, this can result in a data breach, which could cause legal issues, noncompliance with regulations (including HIPAA and GDPR), and harm to the organization's brand. GuardDuty assigns a high severity score of 8.0 because the IP address's inclusion on a custom threat list boosts severity, suggesting the involvement of known adversary infrastructure. The significance of threat intelligence integration, strict access control procedures, and automated remediation workflows (such as banning IPs using AWS WAF or firewall rules or quarantining IAM credentials) is highlighted by incidents of this nature.

The detection process begins with Amazon GuardDuty, which keeps an eye out for indications of questionable activity in AWS CloudTrail, VPC flow, and DNS logs. In your instance, GuardDuty finds that an IP address on your custom threat list was used to access S3 bucket carrd12-guardduty via the GetObject API. GuardDuty's integrated custom threat intelligence feeds cause this detection to happen automatically.

The generated findings are sent to AWS Security Hub, which compiles results from several AWS services. Here, Security Hub creates a centralized dashboard that displays the GuardDuty discovery along with other relevant security data (such as AWS Config compliance violations). Additionally, Security Hub classifies the threat's kind and level of severity, allowing you to prioritize the event via an automated procedure.

To learn more, you can use the AWS CLI to query these results. For instance, you may extract information about the timestamps, the particular object accessed, and the IAM identity involved. Security Hub can also identify non-compliant setups (such as public S3 buckets or lax IAM controls) that contributed to the event if you have activated the AWS Foundational Security Best Practices (FSBP) standard.

Integrating automated remediation processes with AWS Systems Manager Automation and similar solutions. Once the threat was identified, a workflow could:

- Remove the access credentials for the IAM user.
- To prevent access from that IP or actor, change the S3 bucket policy.
- If there is an EC2 instance linked to the activity, isolate or terminate it.
- Use EventBridge or Amazon SNS to alert admins.

Testing

You can use an organized testing procedure to make sure that AWS Security Hub requirements are being correctly applied and that security issues are being found, addressed, and fixed. Start by using the `aws securityhub get-enabled-standards` command to confirm that your compliance standards, like AWS Foundational Security Best Practices, are completely activated. Look for a state of "READY." After that, use GuardDuty to simulate security discoveries by turning on sample findings with the AWS CLI; they are expected to show up in Security Hub in a matter of minutes. Create scenarios like making an S3 bucket public or turning off encryption on EBS volumes to test real-world misconfigurations. Security Hub should identify these as compliance concerns.

If automatic remediation has been set up with AWS Lambda, EventBridge, or Systems Manager Automation, make sure these responses are triggered correctly by keeping an eye on their execution through CloudWatch Logs or Systems Manager. To verify the behavior of automation runbooks, you can also manually invoke them. Finally, make sure your detection and remediation systems are operating as intended by reviewing findings and trends in Security Hub or using Config to track continuous compliance.

Economic Analysis of the System Design

SERVICE	USAGE ASSUMPTION	EST. MONTHLY COST (USD)
AWS S3	50 GB of Standard storage and 100,000 PUT/GET requests	\$1.50
AWS GUARDDUTY	30 million CloudTrail events and 500 GB of VPC Flow Logs analyzed	\$24.00
AWS SECURITY HUB	10,000 security checks and 10,000 finding ingestion events	\$10.00
AWS CONFIG	10 AWS resources with 100 configuration items	\$3.00
AWS CLOUDTRAIL	1 trail with 5 GB of data events	\$2.50
AWS CLOUDWATCH	10 custom metrics and 5 GB of log data ingested	\$7.50
AWS VPC	1 NAT Gateway with 1 GB of data processed	\$32.00
AWS EVENTBRIDGE	100,000 events published	\$1.00
TOTAL ESTIMATED COST		\$81.50

The AWS Pricing Calculator was used in a test and demonstration environment with estimated low consumption in the US-east-1 region to estimate the monthly cost of the conceptual AWS security system. The system has 10 GB of data and 100,000 queries are stored on Amazon S3, which costs about \$0.30. For internet access from private subnets, networking requires a NAT gateway. Processing 10 GB of data comes at a cost of about \$33.40. The

anticipated monthly cost of AWS Config, which tracks 10 resources, is \$1.00.

AWS GuardDuty and Security Hub can be free at first if you qualify for the 30-day free trial. After the trial, the expected monthly cost of GuardDuty, which analyzes 1 GB of logs every day, is \$4.00, while Security Hub, which includes 10 resources and regular compliance checks, adds roughly \$10.00. Due to its free-tier utilization, AWS Systems Manager (Automation and Inventory) and CloudWatch are also utilized, with anticipated expenses of \$0.00 and \$0.50, respectively. The monthly estimate for this architecture is roughly \$65.26, with possible decreases under free-tier limits or during trial periods.

Conclusion and Future Work

In summary, my diagram shows how to use AWS native security services to create a more efficient threat detection and response pipeline. Amazon GuardDuty examines network activity and API calls to detect suspicious activities directed at an S3 bucket. GuardDuty creates a security finding when it detects a possible threat, like an illegal IP accessing items. AWS Security Hub receives this discovery automatically and uses it to compile and rank alerts from various AWS services. Compliance standards like FSBP v1 are enabled to organize and categorize the findings, which can then be reviewed via AWS CLI/SDKs or the AWS Management Console for further investigation and action. To efficiently handle cloud risks, the system focuses on automation, central visibility, and compliance-driven reaction methods.

Although the existing system offers a strong basis for monitoring and detection, further enhancements could go beyond other subjects discussed in MCY 612. For example, more explicit integration of Identity and Access Management (IAM) would improve policy enforcement and access control around the S3 bucket and other resources. Threat coverage could be expanded beyond storage by integrating Infrastructure Protection-Compute, such as EC2 instances with host-based intrusion detection and hardened AMIs. The loop from detection to reaction would be completed by investigating automated remediation utilizing tools like AWS Systems Manager or custom Lambda functions. Last but not least, implementing more sophisticated logging and monitoring using AWS Config or Amazon CloudWatch may provide a more thorough security posture by offering greater insight into past behavior and configuration drift.

References

[1] AWS Foundational Security Best Practices V1.0.0 (FSBP) standard - AWS security hub. (n.d.-a).
<https://docs.aws.amazon.com/securityhub/latest/userguide/fsbp-standard.html>

<https://awscli.amazonaws.com/v2/documentation/api/latest/reference/cloudfront/create-distribution.html>

[2] Batch-enable-standards¶. batch-enable-standards - AWS CLI 2.27.7 Command Reference. (n.d.).
<https://awscli.amazonaws.com/v2/documentation/api/latest/reference/securityhub/batch-enable-standards.html>

[3] Enabling security hub - AWS security hub. (n.d.-b).
<https://docs.aws.amazon.com/securityhub/latest/userguide/securityhub-settingup.html>

[4] Examples of AWS audit manager controls - AWS audit manager. (n.d.-c).
<https://docs.aws.amazon.com/audit-manager/latest/userguide/examples-of-controls.html>

[5] How configuration policies work in security hub - AWS security hub. (n.d.-d).
<https://docs.aws.amazon.com/securityhub/latest/userguide/configuration-policies-overview.html>

[6] Security and compliance - overview of Amazon Web Services. (n.d.-e).
<https://docs.aws.amazon.com/whitepapers/latest/aws-overview/security-and-compliance.html>

[7] Security hub examples using AWS CLI - AWS SDK code examples. (n.d.-f).
https://docs.aws.amazon.com/code-library/latest/ug/cli_2_securityhub_code_examples.html

[8] Setting up AWS config with the AWS cli - AWS config. (n.d.-g).
<https://docs.aws.amazon.com/config/latest/developer-guide/gs-cli.html>

[9] What is AWS Security Hub? - AWS security hub. (n.d.-h).
<https://docs.aws.amazon.com/securityhub/latest/userguide/what-is-securityhub.html>

[10] Cloudfront and edge function logging - amazon Cloudfront. (n.d.-d).
<https://docs.aws.amazon.com/AmazonCloudFront/latest/DeveloperGuide/logging.html>

[11] Create-distribution¶. create-distribution - AWS CLI 2.26.5 Command Reference. (n.d.).